Accordo con il responsabile del trattamento (art. 28 GDPR)

Un modello di accordo tra titolare e responsabile del trattamento ai sensi dell'art. 28 del GDPR, con quattro allegati da compilare e un controllo riga per riga per un accordo già firmato. Per responsabili della protezione dei dati, avvocati e chi gestisce piccole imprese.

PER CHI

Edizione italiana. Per titolari e responsabili del trattamento in Italia, pubblici o privati, che hanno bisogno dell'accordo scritto richiesto dall'art. 28 del GDPR (il regolamento generale sulla protezione dei dati, Regolamento (UE) 2016/679). Il modello segue il diritto dell'UE; le indicazioni italiane sono in una sezione a parte. Le regole per la Germania sono nell'edizione in inglese: https://finoprivacy.com/documents/processor-agreement.html

NON COPERTO

I contitolari del trattamento (art. 26 del GDPR) e i titolari autonomi, che richiedono un documento diverso. Gli strumenti di trasferimento in sé (clausole tipo per i trasferimenti, valutazioni dei trasferimenti). I trattamenti a fini di prevenzione e repressione dei reati ai sensi della direttiva (UE) 2016/680 e i trattamenti delle istituzioni dell'UE ai sensi del regolamento (UE) 2018/1725. Le condizioni commerciali come prezzo, limiti di responsabilità e assicurazione, lasciate come campi da compilare. Non confermato, quindi escluso: indicazioni del Garante dedicate specificamente ai responsabili del trattamento oltre alle tre pagine del Garante indicate tra le fonti (nessuna trovata nella raccolta salvata).

STATO DELLA NORMATIVA

GDPR (Regolamento (UE) 2016/679), testo italiano consolidato su EUR-Lex, letto l'8 novembre 2026; decisione di esecuzione (UE) 2021/915 della Commissione del 4 giugno 2021, testo italiano; Linee guida EDPB 07/2020, testo italiano versione 2.0 (7 luglio 2021); Parere EDPB 22/2024 (7 ottobre 2024), testo italiano non ancora rivisto; parere congiunto EDPB-GEPD 1/2021 (14 gennaio 2021), solo in inglese; registro EDPB delle clausole ai sensi dell'art. 28, par. 8, letto il 7 novembre 2026; Codice privacy, art. 2-quaterdecies, testo vigente su Normattiva (aggiornato all'atto pubblicato il 19 febbraio 2026); pagine del Garante lette l'8 novembre 2026 (copie salvate)

VERSIONE

1.0, 8 novembre 2026

Da verificare prima di usarlo

L'altra parte è un responsabile del trattamento? L'art. 28 si applica solo quando un soggetto distinto tratta dati personali per conto del titolare (art. 4, punto 8)). **Due strade.** Le parti possono stipulare un proprio contratto o altro atto giuridico (art. 28, par. 3), come in questo modello, oppure usare clausole contrattuali tipo adottate dalla Commissione (art. 28, par. 7: decisione di esecuzione (UE) 2021/915) o da un'autorità di controllo (art. 28, par. 8). In entrambi i casi l'accordo è stipulato in forma scritta, anche in formato elettronico (art. 28, par. 9). **Errori riscontrati in casi sanzionati:** un sub-responsabile usato senza autorizzazione, un responsabile che agisce di propria iniziativa (casi nella sezione italiana). **Non è adatto** ai contitolari del trattamento (art. 26) né a due titolari autonomi.

Prima di usare il modello

Chi è il responsabile del trattamento

Il responsabile del trattamento è *"la persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che tratta dati personali per conto del titolare del trattamento"* (art. 4, punto 8), GDPR). Il titolare è chi determina le finalità e i mezzi del trattamento (art. 4, punto 7)). Secondo il Comitato europeo per la protezione dei dati (EDPB), l'organismo che riunisce le autorità di protezione dei dati dell'UE, *"Le due condizioni fondamentali per la qualifica di responsabile del trattamento sono"*: essere un soggetto distinto rispetto al titolare e trattare i dati personali per conto del titolare (Linee guida EDPB 07/2020, punto 76, p. 28).

Non è l'etichetta usata nel contratto a decidere il ruolo. Se un contratto non corrisponde alla realtà del controllo effettivo, secondo l'EDPB *"si può non tenere conto di tale contratto"* (Linee guida EDPB 07/2020, nota 42, p. 35). Un fornitore che usa i dati per finalità proprie è un titolare: nell'esempio dell'EDPB, un'agenzia di viaggi e le compagnie aeree e gli alberghi a cui invia le prenotazioni sono ciascuno titolare, senza alcun rapporto titolare-responsabile tra loro (punto 92).

Due strade: un contratto proprio o le clausole tipo

L'art. 28, par. 3, richiede che i trattamenti siano disciplinati *"da un contratto o da altro atto giuridico a norma del diritto dell'Unione o degli Stati membri, che vincoli il responsabile del trattamento al titolare del trattamento"* (art. 28 GDPR). Le parti possono redigerne uno proprio oppure basarlo *"in tutto o in parte"* su clausole contrattuali tipo (art. 28, par. 6). Secondo l'EDPB *"non vi è alcun obbligo"* di usare le clausole tipo, né queste devono *"necessariamente avere la precedenza"* rispetto a un contratto ad hoc (Linee guida EDPB 07/2020, punto 106).

Le clausole della Commissione. Le clausole allegate alla decisione (UE) 2021/915 *"soddisfano i requisiti per i contratti tra titolari del trattamento e responsabili del trattamento di cui all'articolo 28, paragrafi 3 e 4, del regolamento (UE) 2016/679"* (art. 1 della decisione). Si usano senza modifiche: *"Le parti si impegnano a non modificare le clausole se non per aggiungere o aggiornare informazioni negli allegati"* (clausola 2, lett. a)). Possono essere inserite in un contratto più ampio, con altre clausole che non le contraddicano (clausola 2, lett. b)). *"non garantiscono, di per sé, il rispetto degli obblighi connessi ai trasferimenti internazionali conformemente al capo V"* del GDPR (clausola 1, lett. f)): i trasferimenti verso paesi terzi richiedono un proprio strumento.

Le clausole di un'autorità di controllo. Il registro dell'EDPB delle clausole adottate ai sensi dell'art. 28, par. 8, ne elenca tre serie: Danimarca (10 dicembre 2019), Lituania e Slovenia (entrambe 13 aprile 2023). Nessuna proviene dal Garante italiano (registro dell'EDPB (in inglese), letto il 7 novembre 2026).

Questo modello non è costituito dalle clausole della Commissione. È un contratto individuale ai sensi dell'art. 28, par. 3, redatto da Fino. Segue l'ordine dell'art. 28, par. 3, e la struttura dei modelli ufficiali indicati tra le fonti, non il loro testo. Chi vuole avvalersi delle clausole della Commissione usa il testo ufficiale senza modifiche.

Specifico, non una copia della legge

Secondo l'EDPB l'accordo dovrebbe *"non già meramente ribadire le disposizioni del GDPR"*, ma indicare in concreto come sarà soddisfatto ogni requisito (Linee guida EDPB 07/2020, punto 112). Per questo il modello mette i dettagli in quattro allegati. Un contratto stipulato prima dell'applicazione del GDPR e mai allineato ai suoi requisiti costituisce, secondo l'EDPB, una violazione dell'art. 28, par. 3 (punto 103).

Il modello di accordo

Compila ogni campo. Dove il modello offre opzioni, tienine una e cancella le altre. Ogni riga in corsivo spiega la clausola precedente con parole semplici; cancella queste righe prima della firma.

1. Parti e oggetto

1.1 Il presente accordo sul trattamento dei dati personali (l'"Accordo") è concluso tra _____DENOMINAZIONE, SEDE E CODICE FISCALE O PARTITA IVA DEL TITOLARE_____ (il "Titolare") e _____DENOMINAZIONE, SEDE E CODICE FISCALE O PARTITA IVA DEL RESPONSABILE_____ (il "Responsabile"). L'Accordo disciplina i trattamenti di dati personali che il Responsabile effettua per conto del Titolare in esecuzione di _____TITOLO E DATA DEL CONTRATTO DI SERVIZIO_____ (il "Contratto Principale").

Art. 28, par. 3, GDPR

Indica le due parti e collega l'Accordo al contratto di servizio di cui fa parte.

1.2 I termini definiti nel GDPR, come dati personali, trattamento, interessato e violazione dei dati personali, hanno il significato loro attribuito dall'art. 4 del GDPR.

Art. 4 GDPR

I termini giuridici hanno il significato che dà loro il GDPR. Interessato: la persona a cui si riferiscono i dati. Autorità di controllo: l'autorità nazionale per la protezione dei dati.

1.3 In caso di contrasto tra l'Accordo e il Contratto Principale o qualsiasi altro accordo tra le parti in materia di protezione dei dati personali, prevale l'Accordo. Ciò non vale per le clausole contrattuali tipo adottate dalla Commissione che le parti abbiano sottoscritto: in caso di contrasto con l'Accordo prevalgono tali clausole, come esse stesse prevedono.

Linee guida EDPB 07/2020, punto 103; decisione 2021/914, allegato, clausola 5; decisione 2021/915, allegato, clausola 4

Le clausole sulla protezione dei dati prevalgono sul contratto commerciale, ma le clausole tipo della Commissione, se sottoscritte, prevalgono sull'Accordo. L'EDPB raccomanda di raccogliere in un unico punto le clausole che attuano l'art. 28.

2. Il trattamento

2.1 L'allegato 1 descrive la materia disciplinata e la durata del trattamento, la natura e la finalità del trattamento, il tipo di dati personali e le categorie di interessati. Il Responsabile tratta i dati personali soltanto per le finalità indicate nell'allegato 1.

Art. 28, par. 3, primo comma, GDPR

L'allegato 1 dice che cosa si tratta, di chi, come, perché e per quanto tempo.

L'EDPB chiede precisione: il tipo di dati personali dovrebbe essere *"specificato nel modo più dettagliato possibile"*, e non basta indicare che si tratta di *"dati personali, ai sensi dell'articolo 4, paragrafo 1, del GDPR"* (Linee guida EDPB 07/2020, punto 114).

3. Obblighi e diritti del Titolare

3.1 Il Titolare resta responsabile della conformità al GDPR dei trattamenti che affida al Responsabile. Fornisce al Responsabile i dati personali descritti nell'allegato 1, impartisce le proprie istruzioni in forma documentata e può verificare, prima e durante il trattamento, che il Responsabile rispetti l'Accordo e il GDPR, anche mediante le attività di revisione di cui alla clausola 12.

Art. 28, par. 3, e art. 24 GDPR; Linee guida EDPB 07/2020, punto 114

L'art. 28, par. 3, chiede che il contratto indichi anche gli obblighi e i diritti del titolare.

4. Istruzioni

4.1 Il Responsabile tratta i dati personali soltanto su istruzione documentata del Titolare, anche in caso di trasferimento di dati personali verso un paese terzo o un'organizzazione internazionale, salvo che lo richieda il diritto dell'Unione o nazionale cui è soggetto il Responsabile. In tal caso il Responsabile informa il Titolare circa tale obbligo giuridico prima del trattamento, a meno che il diritto vieti tale informazione per rilevanti motivi di interesse pubblico.

Art. 28, par. 3, lett. a), GDPR

Il responsabile agisce solo su istruzione del titolare. Se una legge dell'UE o nazionale impone altro, lo dice prima, salvo che quella legge lo vieti.

4.2 L'Accordo e i suoi allegati costituiscono le istruzioni iniziali del Titolare. Il Titolare può impartire ulteriori istruzioni per iscritto, anche per posta elettronica, tramite le persone indicate nell'allegato 4. Entrambe le parti conservano ogni istruzione insieme all'Accordo.

Art. 28, par. 3, lett. a), GDPR; Linee guida EDPB 07/2020, punto 118

Ogni istruzione successiva è scritta e conservata, così da poterla dimostrare.

4.3 Il Responsabile informa immediatamente il Titolare qualora, a suo parere, un'istruzione violi il GDPR o altre disposizioni, nazionali o dell'Unione, relative alla protezione dei dati. Il Responsabile può sospendere l'esecuzione di tale istruzione finché il Titolare non la confermi, modifichi o revochi.

Art. 28, par. 3, secondo comma, GDPR; Linee guida EDPB 07/2020, punto 149

Se il responsabile ritiene illecita un'istruzione, lo dice subito. La seconda frase, sulla sospensione, è facoltativa: l'EDPB la indica come esempio. Cancellala se le parti non la concordano.

L'art. 28, par. 3, prevede questo obbligo in un comma a parte: *"il responsabile del trattamento informa immediatamente il titolare del trattamento qualora, a suo parere, un'istruzione violi il presente regolamento o altre disposizioni, nazionali o dell'Unione, relative alla protezione dei dati"* (art. 28 GDPR). Il GDPR non dice che cosa accade dopo. L'EDPB raccomanda di concordarlo, per esempio la sospensione dell'istruzione, o la risoluzione del contratto se il titolare insiste (Linee guida EDPB 07/2020, punto 149). La clausola 15.3 prevede la risoluzione.

4.4 Il Responsabile non tratta i dati personali per finalità proprie o di terzi. Se il Responsabile viola il GDPR determinando le finalità e i mezzi del trattamento, è considerato titolare del trattamento in questione.

Art. 28, par. 10, GDPR

Il responsabile che inizia a decidere perché e come si usano i dati diventa titolare per quell'uso, con gli obblighi del titolare.

Sulle parole *"salvo che lo richieda il diritto dell'Unione o nazionale cui è soggetto il responsabile del trattamento"*, l'EDPB ritiene la loro inclusione *"vivamente raccomandata ma non obbligatoria"*. Per i dati trasferiti fuori dallo Spazio economico europeo (SEE: l'UE più Islanda, Liechtenstein e Norvegia), considera improbabile che una formula più generica come *"salvo che lo richieda il diritto o un ordine vincolante di un organismo pubblico"* basti di per sé (Parere EDPB 22/2024, sintesi). Il testo italiano del parere riporta la nota "This language version has not yet been proofread".

5. Riservatezza

5.1 Il Responsabile consente l'accesso ai dati personali soltanto ai propri dipendenti e collaboratori che ne hanno bisogno per eseguire il Contratto Principale. Garantisce che le persone autorizzate al trattamento dei dati personali si siano impegnate alla riservatezza o abbiano un adeguato obbligo legale di riservatezza. L'impegno riguarda tutti i dati personali trattati per conto del Titolare e permane anche dopo la cessazione dell'attività della persona sui dati.

Art. 28, par. 3, lett. b), GDPR; Linee guida EDPB 07/2020, punti 123-124

Vede i dati solo chi ne ha bisogno, e ciascuno è vincolato al segreto, per contratto o per legge.

5.2 Il Responsabile garantisce che chiunque agisca sotto la sua autorità e abbia accesso ai dati personali li tratti soltanto su istruzione del Titolare, salvo che lo richieda il diritto dell'Unione o degli Stati membri.

Art. 29 e art. 32, par. 4, GDPR

Anche chi lavora sotto il responsabile segue le istruzioni del titolare.

6. Sicurezza

6.1 Il Responsabile adotta tutte le misure richieste ai sensi dell'art. 32 del GDPR. Mette in atto almeno le misure tecniche e organizzative descritte nell'allegato 2, scelte dalle parti tenendo conto dello stato dell'arte, dei costi di attuazione, della natura, dell'oggetto, del contesto e delle finalità del trattamento e dei rischi per i diritti e le libertà delle persone fisiche.

Art. 28, par. 3, lett. c), e art. 32, par. 1, GDPR

Il responsabile protegge i dati al livello richiesto dal rischio. L'allegato 2 elenca le misure concrete.

6.2 Il Responsabile riesamina le misure almeno PERIODICITÀ DEL RIESAME, PER ESEMPIO OGNI 12 MESI e dopo ogni modifica significativa del trattamento. Sostituisce una misura solo con un'altra che garantisca almeno lo stesso livello di sicurezza. Comunica in anticipo al Titolare ogni modifica sostanziale e la attua solo con l'approvazione scritta del Titolare.

Art. 32, par. 1, lett. d), GDPR; Linee guida EDPB 07/2020, punto 126

Le misure si verificano regolarmente e non si indeboliscono mai senza l'accordo del titolare.

7. Sub-responsabili

Tieni l'opzione A o l'opzione B e cancella l'altra.

7.1 **Opzione A, autorizzazione specifica.** Il Responsabile non ricorre a un altro responsabile del trattamento (un "Sub-responsabile") senza previa autorizzazione scritta specifica del Titolare. Trasmette ogni richiesta almeno NUMERO giorni prima del ricorso al Sub-responsabile, con le informazioni indicate nell'allegato 3. La richiesta che non riceve risposta entro tale termine si intende respinta.

Art. 28, par. 2, GDPR; Linee guida EDPB 07/2020, punti 152-155

Ogni nuovo sub-responsabile richiede il sì scritto del titolare. Il silenzio vale come no.

7.2 **Opzione B, autorizzazione generale.** Il Titolare concede la propria autorizzazione scritta generale per i Sub-responsabili elencati nell'allegato 3. Il Responsabile informa per iscritto il Titolare di ogni aggiunta o sostituzione prevista di un Sub-responsabile almeno NUMERO giorni prima, con le informazioni indicate nell'allegato 3, così da consentire al Titolare di opporsi. Se il Titolare si oppone, CONSEGUENZA DELL'OPPOSIZIONE.

Art. 28, par. 2, GDPR; Linee guida EDPB 07/2020, punti 156-158

Il titolare approva in anticipo un elenco. Il responsabile annuncia ogni modifica e il titolare può dire di no. Nel campo, scrivi che cosa segue un'opposizione, per esempio: il responsabile non ricorre al sub-responsabile, oppure ciascuna parte può recedere dal servizio interessato entro un certo numero di giorni.

L'obbligo di informare è attivo. Secondo l'EDPB *"non è sufficiente"* che il responsabile si limiti a dare accesso a un elenco dei sub-responsabili aggiornato periodicamente, senza segnalare ogni nuovo sub-responsabile previsto (Linee guida EDPB 07/2020, nota 54). Con un'autorizzazione generale, la mancata opposizione del titolare entro il termine stabilito può essere interpretata come autorizzazione (punto 157).

7.3 Quando il Responsabile ricorre a un Sub-responsabile per l'esecuzione di specifiche attività di trattamento per conto del Titolare, impone a tale Sub-responsabile, mediante un contratto o un altro atto giuridico a norma del diritto dell'Unione o degli Stati membri, gli stessi obblighi in materia di protezione dei dati previsti dall'Accordo, prevedendo in particolare garanzie sufficienti per mettere in atto misure tecniche e organizzative adeguate. Tra questi obblighi rientra il diritto del Titolare, o di un revisore da esso incaricato, di sottoporre a revisione il Sub-responsabile.

Art. 28, par. 4, GDPR; Linee guida EDPB 07/2020, punti 129 e 160

Gli stessi obblighi scendono lungo la catena. Le parole possono cambiare; la sostanza no.

7.4 Qualora il Sub-responsabile ometta di adempiere ai propri obblighi in materia di protezione dei dati, il Responsabile conserva nei confronti del Titolare l'intera responsabilità dell'adempimento degli obblighi del Sub-responsabile.

Art. 28, par. 4, ultima frase, GDPR

Il responsabile risponde al titolare per i propri sub-responsabili.

7.5 Il Responsabile tiene aggiornato l'allegato 3 con denominazione, indirizzo, referente, attività di trattamento e luogo del trattamento di ogni Sub-responsabile, a ogni livello della catena. Su richiesta del Titolare, fornisce copia del contratto con un Sub-responsabile e delle sue modifiche; può oscurarne il testo solo nella misura necessaria a proteggere segreti commerciali o altre informazioni riservate, compresi dati personali.

Parere EDPB 22/2024, sintesi; decisione 2021/915, allegato, clausola 7.7, lett. c)

Il titolare sa sempre chi tratta i suoi dati, lungo tutta la catena.

8. Richieste degli interessati

8.1 Tenendo conto della natura del trattamento, il Responsabile assiste il Titolare con misure tecniche e organizzative adeguate, nella misura in cui ciò sia possibile, al fine di soddisfare l'obbligo del Titolare di dare seguito alle richieste per l'esercizio dei diritti dell'interessato di cui al capo III del GDPR. L'allegato 2, parte B, descrive queste misure.

Art. 28, par. 3, lett. e), GDPR

Il responsabile aiuta il titolare a rispondere a chi chiede di vedere, correggere, cancellare o trasferire i propri dati.

8.2 Il Responsabile inoltra al Titolare ogni richiesta ricevuta da un interessato entro NUMERO giorni lavorativi e non vi risponde salvo autorizzazione scritta del Titolare.

Linee guida EDPB 07/2020, punti 131-132

Su ogni richiesta decide il titolare. I suoi termini di legge non si sospendono mentre attende il responsabile.

9. Assistenza su sicurezza, violazioni e valutazioni d'impatto

9.1 Tenendo conto della natura del trattamento e delle informazioni a sua disposizione, il Responsabile assiste il Titolare nel garantire il rispetto degli obblighi di cui agli artt. da 32 a 36 del GDPR: sicurezza del trattamento, notifica delle violazioni dei dati personali all'autorità di controllo e comunicazione agli interessati, valutazioni d'impatto sulla protezione dei dati e consultazione preventiva dell'autorità di controllo. L'allegato 2, parte B, descrive le modalità.

Art. 28, par. 3, lett. f), GDPR

Il responsabile aiuta il titolare negli obblighi su sicurezza, notifiche di violazione, valutazioni d'impatto e consultazione dell'autorità.

10. Violazioni dei dati personali

10.1 Il Responsabile notifica al Titolare ogni violazione dei dati personali trattati in base all'Accordo, comprese quelle avvenute presso un Sub-responsabile, senza ingiustificato ritardo dopo esserne venuto a conoscenza e comunque entro NUMERO ore, tramite CANALE, PER ESEMPIO E-MAIL E TELEFONO al punto di contatto indicato nell'allegato 4.

Art. 33, par. 2, GDPR; Linee guida EDPB 07/2020, punto 136

Il GDPR non fissa un numero di ore per il responsabile; l'EDPB dice che le parti possono concordarlo. Il titolare deve notificare la violazione all'autorità senza ingiustificato ritardo e, ove possibile, entro 72 ore dal momento in cui ne è venuto a conoscenza (art. 33, par. 1).

L'EDPB: *"può essere opportuno che le parti includano nel contratto un lasso di tempo specifico (ad esempio, il numero di ore) entro il quale il responsabile del trattamento informa il titolare"* (Linee guida EDPB 07/2020, punto 136). Il progetto di clausole della Commissione prevedeva 48 ore; l'EDPB e il Garante europeo della protezione dei dati (GEPD) hanno suggerito di lasciare il termine alle parti (parere congiunto 1/2021, punto 42 (in inglese)), e le clausole adottate prevedono la notifica *"senza ingiustificato ritardo"* senza un numero di ore (decisione 2021/915, allegato, clausola 9.2).

10.2 La notifica descrive, per quanto possibile: la natura della violazione, compresi le categorie e il numero approssimativo di interessati e di registrazioni dei dati personali in questione; un punto di contatto presso cui ottenere più informazioni; le probabili conseguenze; le misure adottate o di cui si propone l'adozione per porre rimedio alla violazione e attenuarne i possibili effetti negativi. Le informazioni non ancora disponibili sono fornite in fasi successive senza ulteriore ingiustificato ritardo.

Art. 28, par. 3, lett. f), e art. 33, par. 3-4, GDPR

La notifica dà al titolare ciò che gli serve per la propria notifica all'autorità.

10.3 Il Responsabile non notifica la violazione all'autorità di controllo né la comunica agli interessati per conto del Titolare, salvo istruzione scritta del Titolare. Se lo fa su istruzione, trasmette al Titolare copia della notifica e delle informazioni fornite agli interessati.

Linee guida EDPB 07/2020, punto 136

La notifica all'autorità resta un obbligo giuridico del titolare, anche quando la invia il responsabile.

11. Fine del trattamento

11.1 Dopo che è terminata la prestazione dei servizi relativi al trattamento, il Responsabile, su scelta del Titolare, cancella o restituisce al Titolare tutti i dati personali e cancella le copie esistenti, salvo che il diritto dell'Unione o degli Stati membri preveda la conservazione dei dati. La scelta del Titolare è: SCELTA DEL TITOLARE. Il Titolare può modificare la propria scelta per iscritto fino al termine dei servizi.

Art. 28, par. 3, lett. g), GDPR; Linee guida EDPB 07/2020, punto 140

Alla fine decide il titolare: dati restituiti o cancellati, copie comprese. Nel campo scrivi cancellazione, oppure restituzione e il formato della restituzione.

11.2 Il Responsabile completa la cancellazione o la restituzione entro NUMERO giorni, cancella in modo sicuro e conferma per iscritto di averlo fatto. Se una legge gli impone di conservare una parte dei dati, comunica al più presto al Titolare quale legge e quali dati, e continua a proteggere tali dati secondo l'Accordo fino alla loro cancellazione.

Linee guida EDPB 07/2020, punti 141-142

La cancellazione è confermata per iscritto. I dati conservati perché lo impone una legge restano protetti.

12. Informazioni e attività di revisione

12.1 Il Responsabile mette a disposizione del Titolare tutte le informazioni necessarie per dimostrare il rispetto degli obblighi di cui all'art. 28 del GDPR, comprese le informazioni sui sistemi utilizzati, sulle misure di sicurezza, sull'ubicazione dei dati, sui trasferimenti, su chi ha accesso ai dati e sui Sub-responsabili utilizzati.

Art. 28, par. 3, lett. h), GDPR; Linee guida EDPB 07/2020, punto 143

Il titolare può chiedere tutto ciò che gli serve per dimostrare che il trattamento è in regola.

12.2 Il Responsabile consente e contribuisce alle attività di revisione, comprese le ispezioni, realizzate dal Titolare o da un altro revisore da esso incaricato, con un preavviso di NUMERO giorni, o con un preavviso più breve in presenza di indicazioni di inosservanza. Il Responsabile può proporre un revisore; decide il Titolare. Il Titolare può tenere conto delle certificazioni e delle relazioni di revisione in possesso del Responsabile.

Art. 28, par. 3, lett. h), GDPR; Linee guida EDPB 07/2020, punto 144; decisione 2021/915, allegato, clausola 7.6

Il titolare, o un revisore da lui scelto, può controllare il responsabile, anche in loco se serve.

12.3 I costi delle attività di revisione sono ripartiti come segue: REGOLA SUI COSTI. Nessun addebito può essere così elevato da dissuadere il Titolare dall'esercitare i diritti previsti dalla presente clausola.

Linee guida EDPB 07/2020, punto 145

Il GDPR non dice chi paga le revisioni. L'EDPB mette in guardia da costi così alti che le revisioni restino sulla carta.

13. Trasferimenti internazionali

13.1 Il Responsabile trasferisce dati personali verso un paese terzo o un'organizzazione internazionale soltanto su istruzione documentata del Titolare, o se lo richiede il diritto dell'Unione o degli Stati membri cui è soggetto, e in entrambi i casi soltanto nel rispetto del capo V del GDPR. Lo stesso vale per i trasferimenti effettuati dai suoi Sub-responsabili.

Art. 28, par. 3, lett. a), e art. 44 GDPR; Linee guida EDPB 07/2020, punti 119-120

I dati vanno in un paese terzo solo se il titolare lo dispone ed esiste un valido strumento di trasferimento.

13.2 Il Titolare autorizza i seguenti trasferimenti: TRASFERIMENTI AUTORIZZATI, OPPURE: NESSUNO.

Artt. da 44 a 47 GDPR

Per ogni trasferimento indica il paese, il destinatario, la finalità e lo strumento che lo rende lecito: una decisione di adeguatezza (art. 45), clausole tipo di protezione dei dati (art. 46, par. 2, lett. c)), norme vincolanti d'impresa (art. 47) o un altro strumento del capo V. Se non ce ne sono, scrivi: nessuno.

Le clausole della Commissione per i responsabili *"non garantiscono, di per sé, il rispetto degli obblighi connessi ai trasferimenti internazionali conformemente al capo V"* del GDPR (decisione 2021/915, allegato, clausola 1, lett. f)). Quando il responsabile non rientra nell'ambito di applicazione territoriale del GDPR, le clausole della Commissione per i trasferimenti (decisione (UE) 2021/914) *"soddisfano anche i requisiti di cui all'articolo 28, paragrafi 3 e 4, del regolamento (UE) 2016/679"* (decisione 2021/915, considerando 10).

14. Responsabilità e costi

14.1 Ciascuna parte risponde nei confronti degli interessati secondo quanto previsto dall'art. 82 del GDPR. Nessuna disposizione dell'Accordo limita i diritti degli interessati previsti da tale articolo.

Art. 82 GDPR

Nei confronti delle persone interessate decide l'art. 82: il responsabile risponde solo se non ha adempiuto gli obblighi diretti ai responsabili o ha agito in modo difforme o contrario rispetto alle legittime istruzioni del titolare.

14.2 La responsabilità tra le parti, compresi eventuali limiti, è regolata da CLAUSOLE SULLA RESPONSABILITÀ.

Art. 82, par. 5, GDPR

L'art. 82, par. 5, consente alla parte che ha pagato l'intero risarcimento di reclamare dall'altra la sua parte. Ogni altra ripartizione è rimessa all'accordo delle parti. Nel campo, rinvia alle clausole sulla responsabilità del Contratto Principale oppure scrivi le clausole.

14.3 L'assistenza del Responsabile di cui alle clausole 8, 9, 10 e 12 è CORRISPETTIVO DELL'ASSISTENZA.

Art. 28, par. 3, lett. e), f) e h), GDPR

L'art. 28 impone l'assistenza ma non dice nulla sul suo prezzo. Le parti lo concordano qui: compreso nel corrispettivo del Contratto Principale, oppure con i costi indicati per esteso.

15. Durata e cessazione

15.1 L'Accordo ha effetto dal DATA DI INIZIO. Resta in vigore finché il Responsabile tratta dati personali per conto del Titolare, anche dopo la cessazione del Contratto Principale, salvo che sia risolto prima ai sensi della clausola 15.2 o 15.3. La clausola 15.4 stabilisce che cosa si applica dopo la sua cessazione.

Art. 28, par. 3, primo comma (durata), GDPR

L'Accordo dura finché il responsabile ha i dati, non solo quanto il servizio. Se cessa prima, la clausola 15.4 lo mantiene applicabile finché i dati non sono eliminati.

15.2 Il Responsabile informa senza ritardo il Titolare qualora, per qualunque motivo, non sia più in grado di rispettare l'Accordo. Se il Responsabile viola l'Accordo o il GDPR, il Titolare può dargli istruzione di sospendere il trattamento fino a quando non lo rispetti. Se il rispetto non è ripristinato entro NUMERO giorni, o la violazione è grave o persistente, il Titolare può risolvere l'Accordo e le parti del Contratto Principale che comportano il trattamento.

Decisione 2021/915, allegato, clausola 10, lett. a)-b)

Il titolare può fermare il trattamento e risolvere il contratto se il responsabile non rimedia. Le clausole della Commissione prevedono al massimo un mese.

15.3 Se il Titolare insiste su un'istruzione che il Responsabile ha segnalato ai sensi della clausola 4.3 come contraria alla normativa sulla protezione dei dati, il Responsabile può risolvere l'Accordo e le parti del Contratto Principale che comportano il trattamento.

Linee guida EDPB 07/2020, punto 149; decisione 2021/915, allegato, clausola 10, lett. c)

Il responsabile non resta vincolato a un'istruzione illecita: può sciogliere il contratto.

15.4 Dopo la cessazione dell'Accordo, per qualunque causa, il Responsabile continua a rispettarlo integralmente fino a quando tutti i dati personali non siano stati cancellati o restituiti. Le clausole 5, 12 e 14 continuano ad applicarsi anche successivamente per gli obblighi e le pretese sorti in precedenza.

Decisione 2021/915, allegato, clausola 10, lett. d); art. 28, par. 3, lett. g), GDPR

L'intero Accordo continua ad applicarsi finché i dati non sono eliminati. Riservatezza, revisioni e responsabilità restano anche dopo, per quanto accaduto prima.

16. Forma, modifiche e legge applicabile

16.1 L'Accordo e ogni sua modifica sono stipulati in forma scritta, anche in formato elettronico.

Art. 28, par. 9, GDPR

Un accordo orale o tacito non vale; uno elettronico sì.

16.2 Il Responsabile notifica direttamente al Titolare ogni proposta di modifica dell'Accordo. La modifica ha effetto solo con l'approvazione scritta del Titolare. La pubblicazione di una modifica sul sito web del Responsabile non costituisce notifica.

Linee guida EDPB 07/2020, punto 110

Le modifiche si concordano con il titolare, non si pubblicano online.

16.3 L'Accordo è regolato dalla legge ITALIANA O DI ALTRO STATO MEMBRO. Per ogni controversia è competente in via esclusiva il foro di LUOGO. Resta fermo il diritto degli interessati di agire in giudizio ai sensi dell'art. 79 e dell'art. 82, par. 6, del GDPR.

Art. 79 e art. 82, par. 6, GDPR

Il GDPR non stabilisce la legge applicabile né il foro dell'Accordo: le parti li scelgono secondo il diritto dei contratti. Gli interessati conservano il proprio diritto di agire in giudizio ai sensi degli artt. 79 e 82, par. 6.

PER IL TITOLARE: NOME, RUOLO, LUOGO, DATA E FIRMA _____ PER IL RESPONSABILE: NOME, RUOLO, LUOGO, DATA E FIRMA _____

Allegati

Allegato 1: Descrizione del trattamento

Descrivi ogni voce in concreto, poi cancella gli esempi nei campi.

VOCE	DESCRIZIONE
Materia disciplinata	CHE COSA FA IL RESPONSABILE, PER ESEMPIO L'ELABORAZIONE DELLE PAGHE
Durata	PERIODO ESATTO, O I CRITERI CHE LO DETERMINANO
Natura del trattamento	LE OPERAZIONI, PER ESEMPIO RACCOLTA, CONSERVAZIONE, CONSULTAZIONE, CANCELLAZIONE
Finalità	PERCHÉ I DATI SONO TRATTATI
Tipo di dati personali	PER ESEMPIO NOME, INDIRIZZO, COORDINATE BANCARIE, ORARI DI LAVORO
Categorie particolari (art. 9) o dati giudiziari (art. 10), e garanzie aggiuntive	QUALI TIPI E QUALI GARANZIE, OPPURE: NESSUNO
Categorie di interessati	PER ESEMPIO DIPENDENTI, CLIENTI, VISITATORI
Luoghi del trattamento	PAESI E SEDI, COMPRESI QUELLI DEI SUB-RESPONSABILI

Allegato 2: Misure tecniche e organizzative

Descrivi ogni misura che il responsabile applica davvero, in concreto, e la relativa prova. L'elenco indica gli ambiti da coprire; non dice quali misure bastino. Dipende dal rischio (art. 32).

La nota esplicativa del modello di allegato della Commissione recita: *"Le misure tecniche e organizzative devono essere descritte in modo concreto e non genericamente."* (decisione 2021/915, allegato III). Gli ambiti che seguono riprendono l'art. 32, par. 1 e gli esempi di quell'allegato.

Parte A. Sicurezza del trattamento

AMBITO	MISURE APPLICATE	PROVA
Pseudonimizzazione e cifratura dei dati personali (art. 32, par. 1, lett. a))	MISURE	PROVA
Riservatezza, integrità, disponibilità e resilienza permanenti dei sistemi e dei servizi (art. 32, par. 1, lett. b))	MISURE	PROVA
Ripristino tempestivo della disponibilità e dell'accesso ai dati dopo un incidente (art. 32, par. 1, lett. c))	MISURE	PROVA
Test, verifica e valutazione regolari dell'efficacia delle misure (art. 32, par. 1, lett. d))	MISURE	PROVA
Identificazione e autorizzazione dell'utente	MISURE	PROVA
Protezione dei dati durante la trasmissione	MISURE	PROVA
Protezione dei dati durante la conservazione	MISURE	PROVA

AMBITO	MISURE APPLICATE	PROVA
Sicurezza fisica dei luoghi in cui i dati sono trattati	MISURE	PROVA
Registrazione degli eventi	MISURE	PROVA
Configurazione del sistema, compresa la configurazione per impostazione predefinita	MISURE	PROVA
Informatica interna e gestione e governance della sicurezza informatica	MISURE	PROVA
Certificazione o garanzia di processi e prodotti	MISURE	PROVA
Minimizzazione dei dati	MISURE	PROVA
Qualità dei dati	MISURE	PROVA
Conservazione limitata dei dati	MISURE	PROVA
Responsabilizzazione	MISURE	PROVA
Portabilità e cancellazione dei dati	MISURE	PROVA

Parte B. Assistenza al Titolare

OBBLIGO DEL TITOLARE	COME ASSISTE IL RESPONSABILE
Risposta alle richieste degli interessati (art. 28, par. 3, lett. e))	PER ESEMPIO INOLTRO ENTRO I GIORNI CONCORDATI, ESPORTAZIONE, CANCELLAZIONE
Sicurezza del trattamento (art. 32)	DESCRIVERE
Notifica e comunicazione delle violazioni (artt. 33 e 34)	DESCRIVERE, COMPRESI IL CONTATTO PER LE VIOLAZIONI E IL CONTENUTO DELLA NOTIFICA
Valutazioni d'impatto e consultazione preventiva (artt. 35 e 36)	DESCRIVERE

Allegato 3: Sub-responsabili

Elenca ogni sub-responsabile a ogni livello della catena. Con l'opzione A è l'elenco dei sub-responsabili autorizzati; con l'opzione B è l'elenco concordato.

DENOMINAZIONE E INDIRIZZO	REFERENTE	ATTIVITÀ DI TRATTAMENTO	PAESE	STRUMENTO DI TRASFERIMENTO, SE FUORI DAL SEE	DATA
DENOMINAZIONE E INDIRIZZO	REFERENTE	ATTIVITÀ	PAESE	STRUMENTO OPPURE: NESSUNO	DATA
DENOMINAZIONE E INDIRIZZO	REFERENTE	ATTIVITÀ	PAESE	STRUMENTO OPPURE: NESSUNO	DATA

Con ogni richiesta o modifica annunciata, il responsabile trasmette l'identità del sub-responsabile, la sua ubicazione, che cosa farà e le garanzie messe in atto (Linee guida EDPB 07/2020, punto 152).

Allegato 4: Punti di contatto

Indica una persona e un canale per ogni ruolo e tieni l'elenco aggiornato.

RUOLO	TITOLARE	RESPONSABILE
Impartire e ricevere istruzioni	NOME, RUOLO, E-MAIL	NOME, RUOLO, E-MAIL
Notifiche di violazioni dei dati personali	NOME, E-MAIL, TELEFONO	NOME, E-MAIL, TELEFONO
Richieste degli interessati	NOME, E-MAIL	NOME, E-MAIL
Revisioni e richieste di informazioni	NOME, E-MAIL	NOME, E-MAIL
Responsabile della protezione dei dati, se designato	NOME E CONTATTO	NOME E CONTATTO

L'accordo che hai già copre l'art. 28, par. 3?

Leggi l'accordo già firmato e spunta Sì, No o ? per ogni riga. ? significa non so: scrivi a chi hai chiesto. Ogni No è una lacuna rispetto all'articolo.

VOCE	CHE COSA DICE	SÌ	NO	?
Art. 28, par. 3, primo comma GDPR	Stabilisce la materia disciplinata e la durata del trattamento, la natura e la finalità del trattamento, il tipo di dati personali, le categorie di interessati e gli obblighi e i diritti del titolare.	☐	☐	☐
Art. 28, par. 3, lett. a) GDPR	Il responsabile tratta i dati soltanto su istruzione documentata del titolare, anche per i trasferimenti verso paesi terzi o organizzazioni internazionali. Se il diritto dell'Unione o nazionale impone altro, il responsabile ne informa prima il titolare, a meno che quel diritto lo vieti per rilevanti motivi di interesse pubblico.	☐	☐	☐
Art. 28, par. 3, lett. b) GDPR	Il responsabile garantisce che le persone autorizzate al trattamento si siano impegnate alla riservatezza o abbiano un adeguato obbligo legale di riservatezza.	☐	☐	☐
Art. 28, par. 3, lett. c) GDPR	Il responsabile adotta tutte le misure di sicurezza richieste dall'art. 32.	☐	☐	☐
Art. 28, par. 3, lett. d) GDPR	Il responsabile rispetta le condizioni dell'art. 28, par. 2 e 4, per ricorrere a un altro responsabile.	☐	☐	☐
Art. 28, par. 3, lett. e) GDPR	Tenendo conto della natura del trattamento, il responsabile assiste il titolare, con misure tecniche e organizzative adeguate e nella misura in cui ciò sia possibile, nel dare seguito alle richieste degli interessati che esercitano i propri diritti.	☐	☐	☐
Art. 28, par. 3, lett. f) GDPR	Il responsabile assiste il titolare negli obblighi degli artt. da 32 a 36 (sicurezza, notifica e comunicazione delle violazioni, valutazioni d'impatto, consultazione preventiva), tenendo conto della natura del trattamento e delle informazioni a sua disposizione.	☐	☐	☐
Art. 28, par. 3, lett. g) GDPR	Al termine dei servizi il responsabile cancella o restituisce tutti i dati personali, su scelta del titolare, e cancella le copie esistenti, salvo che il diritto dell'Unione o degli Stati membri ne preveda la conservazione.	☐	☐	☐

VOCE	CHE COSA DICE	SÌ	NO	?
Art. 28, par. 3, lett. h) GDPR	Il responsabile mette a disposizione tutte le informazioni necessarie per dimostrare il rispetto dell'art. 28 e consente e contribuisce alle attività di revisione, comprese le ispezioni, del titolare o di un altro soggetto da questi incaricato.	☐	☐	☐
Art. 28, par. 3, secondo comma GDPR	Il responsabile informa immediatamente il titolare qualora, a suo parere, un'istruzione violi il GDPR o altre disposizioni, nazionali o dell'Unione, relative alla protezione dei dati.	☐	☐	☐
Art. 28, par. 2 GDPR	Il responsabile ricorre a un altro responsabile solo con previa autorizzazione scritta, specifica o generale, del titolare. In caso di autorizzazione generale, informa il titolare di ogni aggiunta o sostituzione prevista, dandogli l'opportunità di opporsi.	☐	☐	☐
Art. 28, par. 4 GDPR	Ogni sub-responsabile è vincolato, mediante contratto o altro atto giuridico, agli stessi obblighi in materia di protezione dei dati, e il responsabile conserva nei confronti del titolare l'intera responsabilità dell'adempimento del sub-responsabile.	☐	☐	☐
Art. 28, par. 9 GDPR	L'accordo è stipulato in forma scritta, anche in formato elettronico.	☐	☐	☐

ITALIA

Italia: che cosa aggiungono il Garante e il Codice privacy, decreto legislativo (d.lgs.) 196/2003

Termini. In italiano il processor è il *responsabile del trattamento*, il sub-processor il *sub-responsabile* e il controller il *titolare del trattamento*. Il *responsabile della protezione dei dati* (RPD) è un ruolo diverso (Garante, principi fondamentali del trattamento).

Il contratto designa il responsabile. Il Garante descrive il contratto dell'art. 28 come l'atto con cui il titolare *"designa un responsabile del trattamento attribuendogli specifici compiti"*, e precisa che deve trattarsi di *"un contratto (o altro atto giuridico conforme al diritto nazionale)"* che disciplini almeno le materie dell'art. 28, par. 3 (Garante, principi fondamentali del trattamento). Le FAQ sul registro lo chiamano *"contratto di designazione a responsabile"* (Garante, FAQ sul registro).

Sub-responsabili. La stessa pagina del Garante precisa che il primo responsabile risponde dinanzi al titolare dell'inadempimento del sub-responsabile, *"anche ai fini del risarcimento di eventuali danni"*, salvo dimostri che l'evento dannoso *"non gli è in alcun modo imputabile"* (art. 82, par. 1 e 3, del GDPR). La clausola 7.4 del modello riprende l'art. 28, par. 4.

Persone autorizzate al trattamento. Ai sensi dell'art. 2-quaterdecies del Codice privacy, il titolare o il responsabile *"individuano le modalità più opportune per autorizzare al trattamento dei dati personali le persone che operano sotto la propria autorità diretta"* (comma 2) e possono attribuire specifici compiti a persone fisiche espressamente designate che operano sotto la loro autorità (comma 1) (Normattiva; copia di Fino). L'articolo lascia libera la forma dell'autorizzazione. Opera insieme all'art. 29 del GDPR e alla clausola 5 del modello.

IT-5.3 Il Responsabile autorizza in forma documentata le persone fisiche che trattano i dati personali sotto la sua autorità diretta e impartisce loro istruzioni coerenti con l'Accordo.

Art. 2-quaterdecies, comma 2, Codice privacy; art. 29 GDPR

Facoltativa, per l'Italia: da inserire dopo la clausola 5.2. Documenta chi, presso il responsabile, può trattare i dati. Testo di Fino; il Codice non impone questa clausola e non prescrive la forma.

Il registro del responsabile. Per la descrizione delle categorie di trattamenti nel registro dell'art. 30, par. 2, il Garante afferma che *"è possibile far riferimento a quanto contenuto nel contratto di designazione a responsabile"* (Garante, FAQ sul registro, punto 6). Un allegato 1 preciso serve quindi a entrambi i documenti.

Violazioni. La pagina del Garante sul data breach afferma che il responsabile che viene a conoscenza di una violazione *"è tenuto a informare tempestivamente il titolare"* (Garante, data breach). La clausola 10.1 lo traduce in un numero di ore.

> **Sanzionati, con l'art. 28 tra le violazioni**
>
> **Serfin 97 S.r.l.**, società di recupero crediti in qualità di responsabile del trattamento: € 60.000, Garante, 2024. Aveva aggiunto di propria iniziativa dati di contatto, senza registrarne la fonte né trasmetterli al titolare; il Garante ha accertato la violazione dell'art. 28, par. 3, lett. a), e) e h) (decisione 2024/IT/132). **ISWEB S.p.A.**, fornitore di una piattaforma di whistleblowing in qualità di responsabile del trattamento: € 40.000, Garante, 2022. Si era avvalsa di un fornitore di hosting senza un adeguato accordo ai sensi dell'art. 28, anche senza la previa autorizzazione di un ospedale cliente (decisione 2022/IT/103). Pagine delle decisioni su Fino in inglese.

I dati sulle decisioni provengono da enforcementtracker.com (a cura di CMS) e da GDPRhub (noyb), con licenza CC BY-NC-SA 4.0 (https://creativecommons.org/licenses/by-nc-sa/4.0/), e dalle pubblicazioni delle autorità stesse; ogni pagina di decisione su Fino riporta i dettagli.

Fonti

GDPR, Regolamento (UE) 2016/679, testo italiano consolidato con le rettifiche (EUR-Lex) • Usata per: Articoli citati nel testo, con il link a ciascun articolo; le citazioni sono copiate da questo testo

Decisione di esecuzione (UE) 2021/915 della Commissione, clausole contrattuali tipo tra titolari e responsabili del trattamento (EUR-Lex) • Usata per: La strada della Commissione ai sensi dell'art. 28, par. 7; invariabilità; trasferimenti non coperti; notifica delle violazioni; ambiti dell'allegato III; schema della risoluzione

Decisione di esecuzione (UE) 2021/914 della Commissione, clausole contrattuali tipo per i trasferimenti (EUR-Lex) • Usata per: Clausola 5 sulla prevalenza delle clausole tipo

Linee guida EDPB 07/2020 sui concetti di titolare del trattamento e di responsabile del trattamento ai sensi del GDPR, versione 2.0 (testo italiano) • Usata per: Chi è il responsabile; contenuto e dettaglio del contratto; istruzioni, sicurezza, sub-responsabili, termine per le violazioni, cancellazione, revisioni e costi, istruzioni illecite

Parere EDPB 22/2024 su taluni obblighi derivanti dal ricorso a responsabili e sub-responsabili del trattamento (testo italiano) • Usata per: Identità di tutti i sub-responsabili; la formula "salvo che lo richieda il diritto"

Parere congiunto EDPB-GEPD 1/2021 sulle clausole contrattuali tipo tra titolari e responsabili del trattamento (in inglese) • Usata per: Termine di notifica delle violazioni lasciato alle parti (punto 42)

Registro EDPB: clausole contrattuali tipo e accordi amministrativi (in inglese) • Usata per: Clausole adottate dalle autorità di controllo ai sensi dell'art. 28, par. 8 (letto il 7 novembre 2026)

Garante: principi fondamentali del trattamento • Usata per: Termini, contratto di designazione, responsabilità del sub-responsabile

Garante: FAQ sul registro delle attività di trattamento • Usata per: Registro del responsabile e contratto di designazione

Garante: data breach • Usata per: Il responsabile informa il titolare della violazione

Codice privacy (d.lgs. 196/2003), art. 2-quaterdecies (Normattiva) • Usata per: Persone autorizzate al trattamento

Datatilsynet (Danimarca): clausole contrattuali tipo ai sensi dell'art. 28, par. 3, modello in inglese • Usata per: Solo struttura (ordine di clausole e allegati); nessun testo ripreso

Datenschutzbehörde (Austria): Standardvertragsklauseln für die Zwecke nach Art. 28 DSGVO (gennaio 2020) • Usata per: Solo struttura; nessun testo ripreso